

Documentação das Rotas de Autenticação

Visão geral

As rotas de autenticação da plataforma utilizam o **Supabase Auth** para:

- cadastro de novas contas;
- confirmação de e-mail;
- login com sessão via cookies;
- logout;
- recuperação e redefinição de senha;
- consulta do usuário autenticado.

Todas as rotas ficam dentro de:

`/api/auth`

Além disso, existe a rota:

`/api/me`

responsável por retornar os dados completos do usuário logado.

Resumo das rotas

Rota	Método	Finalidade
<code>/api/auth/signup</code>	POST	Criar nova conta

/api/ auth/ callb ack	G E T	Confirmar e-mail e criar sessão
--------------------------------	-------------	------------------------------------

/api/ auth/ login	P O S T	Autenticar usuário
-------------------------	------------------	--------------------

/api/ auth/ logou t	P O S T	Encerrar sessão
------------------------------	------------------	-----------------

/api/ auth/ recov ery	P O S T	Solicitar recuperação de senha
--------------------------------	------------------	--------------------------------------

/api/ auth/ recov ery	G E T	Validar link de recuperação
--------------------------------	-------------	--------------------------------

/api/ auth/ recov ery	P U T	Redefinir a senha
--------------------------------	-------------	-------------------

/api/ me	G E T	Retornar usuário autenticado
-------------	-------------	---------------------------------

1. Cadastro de conta

POST /api/auth/signup

Cria uma nova conta no Supabase Auth e envia os metadados iniciais do usuário.

Body

```
{  
  "nomeFantasia": "Ótica Visão Clara",  
  "nomeCompleto": "Maria Eduarda de Paula",  
  "email": "duda@email.com",  
  "telefone": "(32) 99999-9999",  
  "password": "senha1234",  
  "confirmPassword": "senha1234"  
}
```

Validações

A rota exige:

- `nomeFantasia` preenchido;
- `nomeCompleto` preenchido;
- `email` preenchido;
- senha com no mínimo **8 caracteres**;
- `password` e `confirmPassword` iguais.

Comportamento

Ao cadastrar, a rota executa:

```
supabase.auth.signUp()
```

com os dados extras:

```
{  
  nome_fantasia,
```

```
nome_completo,  
telefone  
}
```

Também define o redirecionamento de confirmação de e-mail:

```
/api/auth/callback?next=/login?confirmed=1
```

Resposta de sucesso

Caso o Supabase crie sessão imediatamente

```
{  
  "success": true,  
  "message": "Conta criada com sucesso.",  
  "needsEmailConfirmation": false,  
  "redirectTo": "/admin"  
}
```

Caso seja necessária confirmação por e-mail

```
{  
  "success": true,  
  "message": "Conta criada. Verifique seu e-mail para confirmar o cadastro.",  
  "needsEmailConfirmation": true,  
  "redirectTo": "/login"  
}
```

Erros possíveis

400 Bad Request

```
{  
  "error": "Informe o nome da ótica."  
}
```

ou

```
{  
  "error": "A senha precisa ter pelo menos 8 caracteres."  
}
```

ou

```
{  
  "error": "As senhas não coincidem."  
}
```

500 Internal Server Error

```
{  
  "error": "Erro interno ao criar conta."  
}
```

2. Callback de confirmação de e-mail

GET /api/auth/callback

Responsável por receber o **code** enviado pelo Supabase após a confirmação de e-mail e transformá-lo em uma sessão válida.

Query params

P	O	Descrição
a	b	
r	r	
â	i	
m	g	
e	a	
t	t	
r	ó	
o	r	

	i o	
c o d e	S i m	Código de autenticação enviado pelo Supabase
n e x t	N ã o	Página para onde o usuário será redirecionado

Exemplo

`/api/auth/callback?code=abc123&next=/login?confirmed=1`

Comportamento

A rota chama:

```
supabase.auth.exchangeCodeForSession(code)
```

Se o código for válido, o usuário é redirecionado para o valor de `next`.

Redirecionamentos

Sucesso

`/login?confirmed=1`

ou outro destino recebido em `next`.

Código ausente

`/login?error=callback_sem_codigo`

Código inválido

`/login?error=confirmacao_invalida`

Erro inesperado

`/login?error=erro_callback`

3. Login

POST /api/auth/login

Autentica o usuário com e-mail e senha, valida o perfil na tabela `usuarios` e retorna os dados necessários para o front.

Body

```
{  
  
  "email": "duda@email.com",  
  
  "password": "senha1234"  
  
}
```

Validações

A rota exige:

- e-mail preenchido;
- senha preenchida.

Fluxo interno

1. Faz login com:

```
supabase.auth.signInWithPassword()
```

2. Busca o usuário correspondente na tabela:

```
usuarios
```

3. Valida se o perfil existe.
4. Valida se o status do usuário é:

```
ativo
```

5. Atualiza:

```
ultimo_acesso_em
```

6. Retorna o redirecionamento conforme a `role`.

Regra de redirecionamento por perfil

```
if (role === "balcao") return "/balcao";  
  
return "/admin";
```

Resposta de sucesso

```
{  
  
  "success": true,  
  
  "user": {  
  
    "id": "uuid-do-usuario",  
  
    "conta_id": "uuid-da-conta",  
  
    "nome_completo": "Maria Eduarda de Paula",  
  
    "email": "duda@email.com",  
  
    "telefone": "(32) 99999-9999",  
  
    "role": "admin",  
  
    "status": "ativo"  
  
  },  
  
  "redirectTo": "/admin"  
  
}
```

Erros possíveis

400 Bad Request

```
{  
  
  "error": "Informe e-mail e senha."  
  
}
```

401 Unauthorized

```
{  
  
  "error": "E-mail ou senha inválidos."  
  
}
```


403 Forbidden

Perfil não encontrado:

```
{  
  "error": "Perfil de usuário não encontrado."  
}
```

Usuário inativo ou bloqueado:

```
{  
  "error": "Seu acesso está inativo ou bloqueado."  
}
```

500 Internal Server Error

```
{  
  "error": "Erro interno ao fazer login."  
}
```

4. Logout

POST /api/auth/logout

Encerra a sessão ativa do usuário.

Body

Não possui body.

Comportamento

Executa:

```
supabase.auth.signOut()
```

Resposta de sucesso

```
{
```

```
"success": true,  
"redirectTo": "/login"  
}
```

Erros possíveis

400 Bad Request

```
{  
  "error": "Não foi possível sair da conta."  
}
```

500 Internal Server Error

```
{  
  "error": "Erro interno ao sair da conta."  
}
```

5. Solicitar recuperação de senha

POST /api/auth/recovery

Envia um e-mail de recuperação de senha para o usuário.

Body

```
{  
  "email": "duda@email.com"  
}
```

Validação

- `email` obrigatório.

Comportamento

A rota chama:

```
supabase.auth.resetPasswordForEmail()
```

com redirecionamento para:

```
/api/auth/recovery?next=/recovery?mode=update
```

Resposta de sucesso

```
{  
  
  "success": true,  
  
  "message": "Se este e-mail estiver cadastrado, você receberá um link de  
recuperação."  
  
}
```

Essa mensagem é propositalmente genérica para evitar exposição de quais e-mails existem no sistema. Escolha acertadíssima. Segurança sem alarde. 

Erros possíveis

400 Bad Request

```
{  
  
  "error": "Informe seu e-mail."  
  
}
```

ou uma mensagem retornada pelo Supabase.

500 Internal Server Error

```
{  
  
  "error": "Erro interno ao solicitar recuperação."  
  
}
```

6. Callback do link de recuperação

GET `/api/auth/recovery`

Recebe o **code** do Supabase, troca por uma sessão temporária de recuperação e redireciona o usuário para a tela de definição da nova senha.

Query params

P a r â m e t r o	O b j e t o	Descrição
code	String	Código de recuperação enviado pelo Supabase
next	String	Destino após validação do código

Exemplo

`/api/auth/recovery?code=abc123&next=/recovery?mode=update`

Comportamento

A rota executa:

```
supabase.auth.exchangeCodeForSession(code)
```

Redirecionamentos

Sucesso

`/recovery?mode=update`

Código ausente

/recovery?error=link_invalido

Link inválido ou expirado

/recovery?error=link_expirado

Erro inesperado

/recovery?error=erro_recuperacao

7. Redefinir senha

PUT /api/auth/recovery

Atualiza a senha do usuário após ele acessar um link válido de recuperação.

Body

```
{  
  
  "password": "novaSenha123",  
  
  "confirmPassword": "novaSenha123"  
}
```

Validações

- senha obrigatória;
- senha com mínimo de **8 caracteres**;
- confirmação igual à nova senha;
- sessão de recuperação válida.

Comportamento

1. Verifica o usuário autenticado com:

```
supabase.auth.getUser()
```

2. Atualiza a senha:

```
supabase.auth.updateUser({
```

```
password
```

```
})
```

Resposta de sucesso

```
{  
  "success": true,  
  "message": "Senha atualizada com sucesso.",  
  "redirectTo": "/login?password_reset=1"  
}
```

Erros possíveis

400 Bad Request

```
{  
  "error": "A nova senha precisa ter pelo menos 8 caracteres."  
}
```

ou

```
{  
  "error": "As senhas não coincidem."  
}
```

ou erro retornado pelo Supabase.

401 Unauthorized

```
{  
  "error": "Sessão de recuperação inválida ou expirada."  
}
```

500 Internal Server Error

```
{  
  "error": "Erro interno ao redefinir senha."  
}
```

8. Dados do usuário autenticado

GET /api/me

Retorna os dados do usuário atualmente autenticado, incluindo as informações da conta associada.

Comportamento

1. Consulta o usuário autenticado:

```
supabase.auth.getUser()
```

2. Caso exista sessão, busca os dados na tabela:

```
usuarios
```

3. Inclui também os dados vinculados de:

```
contas
```

Resposta de sucesso

```
{  
  
  "authenticated": true,  
  
  "user": {  
  
    "id": "uuid-do-usuario",  
  
    "conta_id": "uuid-da-conta",  
  
    "nome_completo": "Maria Eduarda de Paula",  
  
    "email": "duda@email.com",  
  
    "telefone": "(32) 99999-9999",  
  
    "role": "admin",  
  
    "status": "ativo",  
  
    "ultimo_acesso_em": "2026-05-18T12:00:00.000Z",  
  
    "created_at": "2026-05-10T09:00:00.000Z",  
  },  
}
```

```
"conta": {  
  "id": "uuid-da-conta",  
  "nome_fantasia": "Ótica Visão Clara",  
  "razao_social": "Ótica Visão Clara LTDA",  
  "cnpj": "00.000.000/0001-00",  
  "telefone": "(32) 3333-3333",  
  "email": "contato@oticavisao.com",  
  "status": "ativa"  
}  
}  
}
```

Usuário não autenticado

401 Unauthorized

```
{  
  "authenticated": false,  
  "user": null  
}
```

Usuário autenticado no Supabase, mas sem perfil na tabela

usuarios

404 Not Found

```
{  
  "authenticated": false,  
  "user": null,  
  "error": "Usuário não encontrado."  
}
```

Erro inesperado

500 Internal Server Error

```
{  
  "error": "Erro interno ao buscar usuário logado."  
}
```

Fluxos completos

Fluxo de cadastro

Usuário preenche formulário



POST /api/auth/signup



Conta criada no Supabase



E-mail de confirmação enviado



Usuário clica no link



GET /api/auth/callback



Sessão confirmada



Redirecionamento para /login?confirmed=1

Fluxo de login

Usuário informa e-mail e senha



POST /api/auth/login



Supabase autentica



Sistema busca perfil em usuarios



Valida status do usuário



Atualiza ultimo_acesso_em



Retorna dados e redirectTo

Fluxo de recuperação de senha

Usuário informa e-mail



POST /api/auth/recovery



E-mail de recuperação enviado



Usuário clica no link



GET /api/auth/recovery



Sessão temporária de recovery criada



Redirecionamento para /recovery?mode=update



Usuário informa nova senha



PUT /api/auth/recovery



Senha atualizada



Redirecionamento para /login?password_reset=1

Observações importantes para o front-end

1. Login

Após sucesso no login, o front deve usar:

```
router.push(data.redirectTo)
```

2. Cadastro

Após signup:

- se `needsEmailConfirmation === true`, mostrar mensagem para verificar o e-mail;
 - se `false`, redirecionar diretamente para `redirectTo`.
-

3. Sessão do usuário

A rota `/api/me` deve ser usada para:

- restaurar sessão ao recarregar a aplicação;
 - montar contexto de autenticação;
 - aplicar regras de permissão por `role`;
 - obter dados da conta atual.
-

4. Controle de acesso

O sistema trabalha com pelo menos dois perfis identificados no login:

admin

balcao

Redirecionamento atual:

R	D
o	e
l	s
e	t
	i
	n
	o

b	/
a	b
l	a
c	l
a	c
o	a
	o

d	/
e	a
m	d
a	m
i	i
s	n

5. Status do usuário

Mesmo que o Supabase autentique, o acesso só é liberado se:

```
usuarios.status === "ativo"
```

Caso contrário, a sessão é encerrada imediatamente.

Estrutura recomendada no front

src/

```
|— app/
|   |— login/
|   |— signup/
|   |— recovery/
|
|— hooks/
|   └─ useAuth.js
|
|— services/
|   └─ auth.js
```

Exemplo de serviços:

```
export async function login(payload) {
  const response = await fetch("/api/auth/login", {
    method: "POST",
    headers: {
      "Content-Type": "application/json",
    },
  },
```

```
    body: JSON.stringify(payload),  
  });
```

```
  return response.json();  
}
```